Informe de seguridad y calidad en el desarrollo de software

Cuidarte+ · EP3, iteración 2 · ISY1102 · Sección 002v

Antonella Cuvertino y Miriam Hammami · 20 de octubre de 2026

1. Introducción

Este informe sigue los apartados 1–5 y las subsecciones 3.1–3.4 y 5.1–5.3 de la plantilla oficial proporcionada. El proyecto administra datos clínicos, de modo que se verifican comportamiento funcional, permisos, persistencia y trazabilidad. Los anexos incorporan certificación, análisis estático y relación normativa. Se conservan los documentos previos como antecedentes y se agregan resultados reales de esta sesión, sin reemplazar evidencia ausente por ejemplos de las guías.

1.1 Contexto

Cuidarte+ gestiona usuarios, pacientes, exámenes y documentos clínicos mediante una SPA React, API Express y PostgreSQL. docker-compose.yml declara tres servicios: cuidarteplus-postgres-ev, cuidarteplus-backend-ev y cuidarteplus-frontend-ev. Los puertos de referencia son 15442, 4444 y 3333, respectivamente, sujetos a configuración. El acceso a datos de salud exige priorizar confidencialidad, integridad, disponibilidad y trazabilidad.

Los roles autenticados son administrador, médico y paciente. El visitante anónimo representa un contexto adicional de acceso al registro y login, como indica D1, página 3. Según D1, página 5, el paciente debe disponer de lectura de su información, el administrador de administración completa y el médico de acceso clínico. La matriz de permisos final debe precisar cada operación y resolver discrepancias entre interfaz, API y requisitos.

1.2 Ajustes identificados para esta iteración

No se recibió retroalimentación docente explícita. Los siguientes ajustes derivan del contraste documental y técnico, y deben presentarse como mejoras propuestas por el equipo.

Aspecto	Antecedente	Ajuste de la iteración 2
Auditoría	El encargo menciona logs_auditoria	La tabla observada se llama auditoria; se conserva RF-5.1 y se documenta la equivalencia conceptual
Eliminación	D3 declara PASS de borrado lógico	La API contiene DELETE físico; se exige verificación de persistencia antes de aprobar el caso
Rendimiento	D1 exige menos de 300 ms; D2 admite hasta 300 ms	Se adopta el límite estricto menor de 300 ms; se propone p95 para operacionalizarlo, pendiente de aprobación
Seguridad	Se solicitan resultados de bcrypt y SAST	El login compara contraseñas directamente; no hay reporte SonarQube disponible
Accesibilidad	D1 propone mínimo 12 px	El tamaño aislado no demuestra WCAG; se incorporan criterios medibles y pruebas con usuarios
Normativa	Los antecedentes presentan la Ley 21.719 como vigente	Se distingue régimen vigente y preparación para su entrada en vigor el 1 de diciembre de 2026 [L1]

1.3 Justificación Shift-Left DevSecOps

La estrategia integra revisión de requisitos y amenazas antes de desarrollar; validaciones unitarias y de integración durante la construcción; SAST y revisión de dependencias en integración continua; y E2E, DAST, carga y accesibilidad en un entorno de prueba aislado. Así se detectan temprano errores de autorización, pérdida de información y exposición de datos. La automatización debe producir artefactos vinculados a la versión evaluada. El uso de Docker facilita reproducibilidad, pero no acredita seguridad ni cumplimiento por sí mismo.

La copia de código de la entrega omite .env, archivos subidos y dump preexistente. Se sustituyó únicamente la credencial de respaldo de db.js por un valor sintético. No se corrigieron las vulnerabilidades del código durante la actividad. Las pruebas se ejecutaron automáticamente con asistencia técnica; la autoría de la ejecución no se atribuye retrospectivamente a una integrante. Las estudiantes deben revisar y dominar los resultados para la defensa individual.

2. Criterios de calidad

2.1 Calidad técnica

Se utiliza ISO/IEC 25010 como marco de calidad; su edición 2023 define un modelo de calidad de producto [T1]. Los umbrales siguientes provienen de D1 y D2 o son propuestas operativas expresamente identificadas; no se atribuyen a ISO.

Dimensión	Criterio verificable	Evidencia requerida
Adecuación funcional	Login, CRUD, adjuntos y permisos conformes a requisitos; eliminación lógica confirmada	Aserciones API, registros persistidos y capturas del flujo
Desempeño	API simple menor de 300 ms; dashboard menor de 2 s; transferencias menores de 10 s	Resultados por operación y tamaño de archivo; contexto de red y equipo
Capacidad	200 usuarios concurrentes sin HTTP 5xx ni pérdida de datos	JTL de JMeter, métricas de contenedores y base de datos
Accesibilidad	WCAG 2.1 AA en las pantallas evaluadas	Revisión automática y manual por criterio; registro de excepciones
Disponibilidad	Objetivo mensual 99,5%	Monitoreo del período; una ejecución de carga no basta
Recuperación	Respaldos y restauración verificables	Acta de restauración; RPO y RTO acordados, aún no especificados

Para accesibilidad se comprueban contraste de texto normal de al menos 4,5:1 y de texto grande de 3:1, ampliación al 200% sin pérdida de contenido o función, teclado, foco visible, etiquetas y errores comprensibles [T2]. Se recomienda texto base de 16 px para este público como decisión de diseño, sin presentarlo como un mínimo normativo WCAG. Una muestra exploratoria propuesta de cinco adultos mayores permitirá observar comprensión y bloqueos; no acredita por sí sola conformidad AA de toda la aplicación.

2.2 Seguridad de la información

Control	Criterio de aceptación	Comprobación
Autenticación JWT	Rechazar tokens ausentes, alterados y vencidos; acordar vigencia y revocación	Pruebas negativas y revisión de configuración; JWT firmado no implica contenido cifrado
Contraseñas	Hash adaptativo bcrypt con costo calibrado y comparación segura; nunca texto claro	Inspección de implementación y datos sintéticos persistidos
Transporte	HTTPS/TLS en despliegue objetivo y protección de conexión a PostgreSQL	Configuración y negociación observadas; el Compose local HTTP no demuestra TLS
SQLi	Parámetros para valores y listas permitidas para identificadores	Revisión del flujo entrada-consulta y pruebas negativas
XSS	Codificación contextual de salida y tratamiento seguro de contenido	Pruebas en campos persistidos y vistas; sanitización genérica no basta
RBAC e IDOR	Autorizar operación y pertenencia del recurso en servidor	Matriz de roles, dos pacientes diferentes y acceso directo a adjuntos
Auditoría	Actor, acción, recurso, instante y origen; permisos mínimos y detección de alteración	Pruebas con rol de aplicación y verificación del esquema

La prevención de CSRF se evaluará según el mecanismo real de sesión, especialmente si se usan cookies automáticas. Los secretos deben gestionarse fuera de archivos de documentación y las credenciales de demostración deben reemplazarse antes de producción. No se reproducen secretos del repositorio en este informe.

2.3 Cumplimiento y privacidad

Al 20 de octubre de 2026 se distingue la Ley 19.628 vigente del régimen reformado por la Ley 21.719, cuya entrada en vigor general está prevista para el 1 de diciembre de 2026 [L1, L3]. Se debe documentar finalidad, base habilitante, acceso restringido, deber de confidencialidad y gestión de solicitudes de titulares. No se presume que el consentimiento sea la única base posible para todos los tratamientos de salud.

La Ley 21.663 delimita servicios esenciales y operadores de importancia vital; la aplicabilidad a CreaLab y al establecimiento de salud requiere precisar su actividad y calificación [L2]. Se propone auditoría protegida como control de trazabilidad. No se atribuye a la ley la exigencia literal de una tabla denominada logs_auditoria ni de una columna IP en todo registro. La retención debe justificarse por finalidad y obligaciones aplicables; no se inventa un plazo universal ni se equipara soft delete con supresión efectiva de datos.

3. Plan de pruebas

3.1 Estrategia de pruebas

Se aplica enfoque mixto basado en riesgo: primero acceso a datos y privilegios, después integridad, funcionamiento y rendimiento. Secuencia: revisar D1/D2 y criterios; preparar datos sintéticos; ejecutar casos sin corregir rutas; guardar respuestas y consultas; clasificar incidentes; proponer corrección y retest. El flujo requiere trazabilidad requisito → caso → resultado → evidencia → defecto → decisión.

Entrada: versión identificada, base cuidarte_qa separada, API accesible, cuentas por rol y casos definidos. Salida: todos los casos críticos/altos ejecutados; cero defectos críticos y altos abiertos; cobertura backend superior al 80%; SAST/DAST revisados; carga representativa y accesibilidad sin bloqueos. Los criterios de salida no se cumplen y se rechaza el despliegue productivo.

No se recibió ERS íntegra ni feedback docente. Los ajustes de esta iteración provienen del contraste técnico, no de una supuesta retroalimentación. No se afirma cobertura 100% de requisitos sin denominador verificable.

3.2 Tipos de prueba

Tipo	Origen del caso y justificación	Aplicación real
Funcional	RF-1.1 y RF-3.1; confirmar uso correcto y validaciones	Login válido/incorrecto, campos obligatorios y registro clínico
Integración	RF-4.3/4.4 y RF-5.1; verificar API-base-documento	Persistencia, bytes del adjunto y evento de rol
Seguridad	NFR-SEG-2/4/9; proteger datos y privilegios	JWT inválidos, IDOR, contraseñas, escalamiento y acceso anónimo
Rendimiento	NFR-PERF-1/3; evitar demoras de atención	Consulta individual y lote breve de 200 solicitudes
Análisis estático	Auditar el código sin ejecutar rutas	SonarQube y revisión manual diferenciados
Usabilidad/accesibilidad	NFR-USAB-1; población adulta mayor	Antecedentes UI disponibles; evaluación AA completa pendiente

La prueba funcional comprueba el comportamiento esperado; integración verifica el efecto en base y archivos; seguridad añade actores hostiles o insuficientemente autorizados; rendimiento mide tiempo y capacidad bajo condiciones registradas. Que un login funcione no demuestra que la contraseña esté protegida. Que IDOR falle en una ruta no prueba que toda la API esté protegida.

3.3 Criterios de aceptación

Cada caso debe cumplir todos sus resultados esperados y conservar evidencia. No basta un HTTP 200: para borrado se consulta persistencia; para PDF se comparan bytes; para roles se inspecciona usuario_roles. PASS corresponde al alcance verificado; FAIL a desviación observada; BLOCKED a precondición no disponible; SKIPPED a exclusión justificada antes de ejecutar. No se suman pruebas históricas ni inspecciones como nuevas ejecuciones.

Se requiere 401 sin sesión y 403 para operaciones prohibidas; se documenta por separado el 404 usado para ocultar recursos ajenos en /examenes/:id. La latencia objetivo menor de 300 ms proviene de D1; p95 es una operacionalización propuesta y se reportan máximos. Una muestra de carga breve no demuestra disponibilidad mensual del 99,5% ni una prueba sostenida de usuarios reales.

3.4 Herramientas utilizadas

Herramienta/recurso	Uso comprobado o planificado	Fundamento
Node.js v22.16.0	Usado: runner fetch, JWT y PostgreSQL	Reproduce peticiones y verifica respuestas sin modificar rutas
PostgreSQL 15.19 en Docker	Usado: base nueva, esquema init.sql y datos sintéticos	Permite contrastar persistencia y privilegios
SonarQube Community y escáner oficial	Pendiente de análisis completo	Inspecciona calidad y seguridad de código; no sustituye DAST
Python, python-docx, python-pptx y ReportLab	Usado: consolidación, Word, PowerPoint, PDF y CSV	Entrega editable y artefactos verificables
Playwright/Chromium	Apoyo para capturas si consta acta en evidencias	Capturas de interfaz y panel; no implica certificación de accesibilidad
Jest/Supertest, Cypress/Selenium, JMeter y ZAP	Planificados; no presentados como ejecutados	Ampliar unitarias/cobertura, E2E, carga sostenida y DAST

Recursos humanos propuestos: Antonella coordina QA/DevSecOps y automatización; Miriam coordina casos, trazabilidad y cumplimiento. Ambas deben revisar toda la entrega. Entorno real: Windows local, API http://127.0.0.1:4445 y PostgreSQL en 127.0.0.1:15443, datos creados por el script. SonarQube se limita a localhost:9000. Las versiones de dependencias se incluyen en package-lock y las de análisis en 06_Evidencias/sonarqube.

4. Diseño de casos de prueba

Se conservan ocho casos maestros del plan. Las doce comprobaciones automatizadas son puntos de verificación derivados y no se cuentan como doce ejecuciones completas de esos ocho casos. Cada ficha incorpora ID, nombre, requisito, descripción, precondiciones, pasos, esperado, aceptación y datos, tal como exige la plantilla. Se agregan cuatro casos de aula equivalentes al riesgo de Cuidarte+ en la actividad de rol QA, sin afirmar que el sistema sea Atlas o Conecta+.

CP-FUNC-001 — Autenticación y sesión JWT

Requerimiento: RF-1.1; NFR-SEG-9

Descripción: Verificar autenticación y sesión jwt y su efecto técnico en el sistema clínico.

Precondiciones: Cuenta sintética por rol y API disponible.

Pasos: 1. Enviar login válido. 2. Verificar firma y expiración. 3. Consultar recurso permitido. 4. Repetir con credenciales incorrectas y JWT inválidos.

Resultado esperado: 200 y JWT verificable; 401 para credenciales o sesiones inválidas.

Criterio de aceptación: Todos los escenarios deben cumplir el contrato sin exponer secretos. El hash se verifica por separado en CP-API-008.

Datos de prueba: Usuario qa_admin_<ejecución>; contraseña sintética válida y una incorrecta; JWT alterado y vencido.

Resultado y alcance: CP-API-001, 002 y 005: PASS; política de revocación pendiente.

CP-FUNC-002 — Registrar examen y adjuntar PDF

Requerimiento: RF-3.1; RF-4.3/4.4

Descripción: Verificar registrar examen y adjuntar pdf y su efecto técnico en el sistema clínico.

Precondiciones: Médico y dos pacientes sintéticos, tipo de examen válido.

Pasos: 1. POST /examenes. 2. POST /documentos multipart con documento, examen_medico_id y paciente_id. 3. Descargar como titular. 4. Comparar bytes. 5. Intentar como paciente ajeno.

Resultado esperado: 201 para creación/carga, descarga íntegra para titular y 403 para ajeno.

Criterio de aceptación: Sin alteración de bytes ni divulgación a terceros. El archivo mínimo valida transporte; no acredita validación semántica de un PDF clínico.

Datos de prueba: PDF sintético de transferencia; paciente A propietario y paciente B ajeno.

Resultado y alcance: CP-API-006: PASS para transporte y autorización. UI y formatos adicionales pendientes.

CP-FUNC-003 — Borrado lógico y confirmación

Requerimiento: RF-3.3

Descripción: Verificar borrado lógico y confirmación y su efecto técnico en el sistema clínico.

Precondiciones: Examen sintético y administrador.

Pasos: 1. En UI cancelar confirmación y comprobar que permanece. 2. Confirmar como administrador. 3. Consultar fila física y marca de eliminación. 4. Comprobar listados y auditoría.

Resultado esperado: Fila conservada con marca lógica; cancelar no modifica; permisos insuficientes con 403.

Criterio de aceptación: No se permite eliminación física. La prueba API comprueba persistencia; la confirmación visual se valida aparte.

Datos de prueba: Examen creado por el script; paciente asociado.

Resultado y alcance: CP-API-007: FAIL, cero filas tras DELETE. Confirmación UI: antecedente D3, no reejecutada como caso completo.

CP-SEG-001 — Protección frente a SQLi en entradas reales

Requerimiento: NFR-SEG-5

Descripción: Verificar protección frente a sqli en entradas reales y su efecto técnico en el sistema clínico.

Precondiciones: Ruta de búsqueda de servidor identificada; instancia sintética.

Pasos: 1. Localizar si la búsqueda se ejecuta en cliente o servidor. 2. Enviar entradas al parámetro real. 3. Comparar resultados. 4. Revisar parametrización y errores.

Resultado esperado: Sin ampliación de acceso, cambios no autorizados ni errores SQL expuestos.

Criterio de aceptación: Los valores se parametrizan; no se presume vulnerabilidad por concatenar fragmentos fijos.

Datos de prueba: Texto normal, apóstrofe y entrada no destructiva de prueba.

Resultado y alcance: Prueba dinámica específica BLOCKED: no se identificó parámetro de búsqueda textual en GET /examenes. Revisión manual parcial: parámetros observados.

CP-SEG-002 — RBAC e IDOR

Requerimiento: NFR-SEG-4

Descripción: Verificar rbac e idor y su efecto técnico en el sistema clínico.

Precondiciones: Pacientes A y B con recursos separados.

Pasos: 1. Acceder a recurso propio. 2. Acceder como B a /examenes/paciente/:id y al documento. 3. Probar edición privilegiada y eliminación sin sesión.

Resultado esperado: Acceso propio permitido; 403 para ajeno y 401 sin sesión; rol solo modificable por administrador.

Criterio de aceptación: Todos los recursos y operaciones deben aplicar autorización del servidor. En /examenes/:id el código usa 404 como ocultación, pendiente de acordar contrato.

Datos de prueba: JWT de A y B; examen y PDF de A.

Resultado y alcance: CP-API-004 y autorización PDF PASS; CP-API-010 y 012 FAIL. El caso amplio no se aprueba con una sola ruta correcta.

CP-PERF-001 — Capacidad y rendimiento

Requerimiento: NFR-PERF-1/2/3

Descripción: Verificar capacidad y rendimiento y su efecto técnico en el sistema clínico.

Precondiciones: Host, base y API aislados; dataset y mezcla representativos.

Pasos: 1. Registrar entorno. 2. Ejecutar lote y capturar tiempos/HTTP. 3. Evaluar p95 y errores. 4. Ampliar a 10 minutos y mezcla clínica en JMeter. 5. Medir dashboard con navegador.

Resultado esperado: API menor de 300 ms y cero 5xx; dashboard menor de 2 s.

Criterio de aceptación: El lote breve solo permite concluir sobre su alcance; no acredita estabilidad prolongada, carga de UI o SLA mensual.

Datos de prueba: 200 solicitudes simultáneas GET /examenes con JWT sintético; extensión planificada a 200 usuarios sostenidos.

Resultado y alcance: FAIL en lote real: p95 8698 ms, 0 errores. JMeter sostenido pendiente.

CP-USAB-001 — Accesibilidad y uso por adultos mayores

Requerimiento: NFR-USAB-1; NFR-COMPAT-2

Descripción: Verificar accesibilidad y uso por adultos mayores y su efecto técnico en el sistema clínico.

Precondiciones: Pantallas críticas, teclado, lector de pantalla y evaluación informada.

Pasos: 1. Recorrer con teclado. 2. Revisar foco, etiquetas y errores. 3. Medir contraste. 4. Ampliar 200%. 5. Observar tareas con adultos mayores.

Resultado esperado: Contraste 4,5:1 en texto normal y 3:1 en grande; contenido y función conservados; sin bloqueos.

Criterio de aceptación: Todos los criterios WCAG 2.1 AA aplicables al alcance deben documentarse, con revisión manual y usuarios.

Datos de prueba: Escritorio y móvil; zoom 200%; tareas de login, consulta y descarga.

Resultado y alcance: BLOCKED para certificación AA: no se realizó auditoría completa ni estudio con usuarios. Capturas no bastan.

CP-CUMP-001 — Trazabilidad de cambios de rol

Requerimiento: RF-5.1

Descripción: Verificar trazabilidad de cambios de rol y su efecto técnico en el sistema clínico.

Precondiciones: Administrador, usuario sintético y acceso de consulta a base QA.

Pasos: 1. PUT /usuarios/:id con rol_id. 2. Consultar evento. 3. Revisar actor, acción, fecha y origen. 4. Ensayar permisos UPDATE/DELETE y fallo de auditoría con rol de aplicación.

Resultado esperado: Cambio con traza completa y origen confiable; protección frente a alteración y atomicidad.

Criterio de aceptación: No se considera inmutable una tabla común sin controles. No es obligatorio por ley usar el nombre logs_auditoria.

Datos de prueba: Cambio de rol de usuario B; tabla real auditoria.

Resultado y alcance: CP-API-009 FAIL: evento sin columna IP. Inmutabilidad y atomicidad: revisión parcial, ensayo específico pendiente.

Trazabilidad y cobertura

Caso maestro	Comprobaciones / evidencia	Estado del alcance
CP-FUNC-001	CP-API-001, 002 y 005: PASS; política de revocación pendiente.	Ver detalle; cobertura parcial o fallo
CP-FUNC-002	CP-API-006: PASS para transporte y autorización. UI y formatos adicionales pendientes.	Ver detalle; cobertura parcial o fallo
CP-FUNC-003	CP-API-007: FAIL, cero filas tras DELETE. Confirmación UI: antecedente D3, no reejecutada como caso completo.	Ver detalle; cobertura parcial o fallo

Caso maestro	Comprobaciones / evidencia	Estado del alcance
CP-SEG-001	Prueba dinámica específica BLOCKED: no se identificó parámetro de búsqueda textual en GET /examenes. Revisión manual parcial: parámetros observados.	BLOCKED
CP-SEG-002	CP-API-004 y autorización PDF PASS; CP-API-010 y 012 FAIL. El caso amplio no se aprueba con una sola ruta correcta.	Ver detalle; cobertura parcial o fallo
CP-PERF-001	FAIL en lote real: p95 8698 ms, 0 errores. JMeter sostenido pendiente.	Ver detalle; cobertura parcial o fallo
CP-USAB-001	BLOCKED para certificación AA: no se realizó auditoría completa ni estudio con usuarios. Capturas no bastan.	BLOCKED
CP-CUMP-001	CP-API-009 FAIL: evento sin columna IP. Inmutabilidad y atomicidad: revisión parcial, ensayo específico pendiente.	Ver detalle; cobertura parcial o fallo

Cobertura de requisitos = requisitos con casos trazados / total de requisitos de ERS × 100. La ERS completa no se recibió; se informa cobertura temática de los ocho casos solicitados y no una cifra de cobertura total. Se requieren casos adicionales para CRUD completo, respaldos, restauración, cifrado en reposo, retención y otros adjuntos.

5. Ejecución de pruebas

5.1 Resumen de ejecución

Conjunto	Diseñados	Ejecutados	PASS	FAIL	BLOCKED
Comprobaciones API automatizadas	12	12	6	6	0
Casos maestros integrales	8	No se declara ejecución integral de todos	Ver correspondencia	Ver correspondencia	SQLi y WCAG pendientes
Lote breve de carga	1	1	0	1	0
UI histórica D3	5	5 declarados en D3	5 declarados	0 declarados	No recontar como actuales

La tasa de éxito de las comprobaciones API ejecutadas es 6/12 = 50%; la tasa de ejecución de esa suite es 100%. El lote de carga es un experimento separado y no se suma a los doce checkpoints. Los cinco PASS históricos de interfaz se conservan como declaraciones de D3, sin probar persistencia ni seguridad actuales. La fecha y el actor automatizado constan en cada fila de resultados_api.json; las integrantes deben validar el expediente.

Carga real: 200 solicitudes lanzadas en paralelo, máximo 200 en vuelo; duración 9321 ms; p50 8537 ms, p95 8698 ms, p99 8713 ms, máximo 8741 ms; 0 HTTP 5xx y 0 errores. Se concluye FAIL frente al umbral, sin inferir estabilidad de diez minutos. Las descargas de herramientas y el host compartido limitan la generalización de estas cifras; la demora de 5000 ms está además explícita en el código.

5.2 Detalle de ejecución de casos

Caso	Descripción	Resultado	Evidencia	Tipo
CP-API-001	Login válido y JWT	PASS; HTTP 200; firma válida=true	06_Evidencias/api/resultados_api.json → CP-API-001	API / integración / seguridad

Caso	Descripción	Resultado	Evidencia	Tipo
CP-API-002	Credenciales inválidas	PASS; HTTP 401	06_Evidencias/api/resultados_api.json → CP-API-002	API / integración / seguridad
CP-API-003	Campos obligatorios de examen	PASS; HTTP 400	06_Evidencias/api/resultados_api.json → CP-API-003	API / integración / seguridad
CP-API-004	IDOR por paciente ajeno	PASS; HTTP 403	06_Evidencias/api/resultados_api.json → CP-API-004	API / integración / seguridad
CP-API-005	JWT alterado y vencido	PASS; Alterado 401; vencido 401	06_Evidencias/api/resultados_api.json → CP-API-005	API / integración / seguridad
CP-API-006	Registro y adjunto PDF	PASS; Crear 201; subir 201; propio 200; ajeno 403	06_Evidencias/api/resultados_api.json → CP-API-006	API / integración / seguridad
CP-API-007	Persistencia de borrado lógico	FAIL; HTTP 200; filas persistidas=0	06_Evidencias/api/resultados_api.json → CP-API-007	API / integración / seguridad
CP-API-008	Contraseña con hash adaptativo	FAIL; Formato bcrypt=false; igualdad con entrada=true	06_Evidencias/api/resultados_api.json → CP-API-008	API / integración / seguridad
CP-API-009	Auditoría de cambio de rol con origen	FAIL; HTTP 400; columnas=id, usuario_id, accion, fecha_hora	06_Evidencias/api/resultados_api.json → CP-API-009	API / integración / seguridad
CP-API-010	Médico no puede asignarse administrador	FAIL; HTTP 400; roles=medico	06_Evidencias/api/resultados_api.json → CP-API-010	API / integración / seguridad
CP-API-011	Latencia de consulta menor de 300 ms	FAIL; HTTP 200; 5120 ms	06_Evidencias/api/resultados_api.json → CP-API-011	Rendimiento
CP-API-012	Eliminar usuario sin autenticar	FAIL; HTTP 200; filas restantes=0	06_Evidencias/api/resultados_api.json → CP-API-012	API / integración / seguridad

Fecha de ejecución: 20 de octubre de 2026 (los JSON usan UTC ISO 8601). Actor de ejecución: automatización QA asistida. Entorno, esperado, obtenido y evidencia están incluidos caso a caso en el JSON y en la bitácora CSV. No se incluyen tokens completos ni contraseñas en resultados.

Análisis estático

SonarQube no cuenta todavía con exportación completa. No se inventan métricas. La revisión manual confirma rutas y parámetros; no confirma SQLi en un controlador inexistente.

5.3 Criticidad de incidentes

Nivel	Descripción	Impacto	Tratamiento
CRÍTICO	Acceso privilegiado o acción destructiva sin autorización	Confidencialidad e integridad severamente comprometidas	Bloquear despliegue; remediación y retest prioritarios
GRAVE	Función principal, protección de datos o trazabilidad incumplida	Alto; el sistema puede operar parcialmente	Corregir antes de producción

Nivel	Descripción	Impacto	Tratamiento
MODERADO	Desviación secundaria sin bloqueo principal	Medio; existe alternativa aceptable	Planificar corrección con responsable
LEVE	Texto o apariencia sin efecto funcional	Bajo	Resolver por prioridad acordada

Incidente	Caso	Criticidad	Descripción	Resultado observado
DEF-001	CP-API-009	GRAVE / Alta	Auditoría sin origen IP	El cambio devuelve 200 y existe evento, pero auditoria solo contiene id, usuario_id, accion y fecha_hora.
DEF-002	CP-API-008	GRAVE / Alta	Contraseñas en texto claro	La contraseña persistida es idéntica a la entrada y no tiene formato bcrypt.
DEF-003	CP-API-007	GRAVE / Alta	Eliminación física de exámenes	DELETE responde 200 y la consulta posterior retorna cero filas.
DEF-004	CP-API-011	GRAVE / Alta	Latencia fuera de criterio	GET /examenes supera 300 ms; hay d elayMiddleware(5000) .
DEF-005	CP-API-010	CRÍTICO	Escalamiento de médico a administrador	Médico modifica su propio rol con HTTP 200 y queda como admin en usuario_roles.
DEF-006	CP-API-012	CRÍTICO	Eliminación de usuario sin autenticar	DELETE /usuarios/:id sin token devuelve 200 y elimina la cuenta sintética.

Se identificaron seis defectos de ejecución: dos críticos y cuatro graves. Se encuentran abiertos; no hubo remediación ni retest de cierre. Los hallazgos SonarQube se registran aparte y no se suman automáticamente como defectos únicos, porque pueden duplicar problemas o requerir revisión contextual.

DEF-001 — Auditoría sin origen IP

Caso y severidad: CP-API-009; GRAVE / Alta. **Entorno:** API 4445, base cuidarte_qa sintética. **Estado:** abierto.

Pasos reproducibles: ejecutar el script y localizar CP-API-009; la ficha de caso y el código del runner contienen peticiones, datos sintéticos y comprobación de base. **Esperado:** Cambio auditado con origen IP. **Obtenido:** El cambio devuelve 200 y existe evento, pero auditoria solo contiene id, usuario_id, accion y fecha_hora.

Impacto: Dificulta correlación e investigación de cambios privilegiados. **Recomendación:** Capturar origen validado, evento estructurado y transacción; limitar privilegios y retestar proxies. **Evidencia:** resultados_api.json, fila CP-API-009, y capturas del resumen de ejecución. **Responsable propuesto:** desarrollo backend; revisión QA. **Retest:** repetir positivo y negativo, comprobar persistencia y ejecutar regresión de roles y sesiones.

DEF-002 — Contraseñas en texto claro

Caso y severidad: CP-API-008; GRAVE / Alta. **Entorno:** API 4445, base cuidarte_qa sintética. **Estado:** abierto.

Pasos reproducibles: ejecutar el script y localizar CP-API-008; la ficha de caso y el código del runner contienen peticiones, datos sintéticos y comprobación de base. **Esperado:** Hash bcrypt; no texto claro. **Obtenido:** La contraseña persistida es idéntica a la entrada y no tiene formato bcrypt.

Impacto: Compromiso de cuentas si se expone la base. **Recomendación:** Hash adaptativo, migración y verificación segura; retest de login. **Evidencia:** resultados_api.json, fila CP-API-008, y capturas del resumen de ejecución. **Responsable propuesto:** desarrollo backend; revisión QA. **Retest:** repetir positivo y negativo, comprobar persistencia y ejecutar regresión de roles y sesiones.

DEF-003 — Eliminación física de exámenes

Caso y severidad: CP-API-007; GRAVE / Alta. **Entorno:** API 4445, base cuidarte_qa sintética. **Estado:** abierto.

Pasos reproducibles: ejecutar el script y localizar CP-API-007; la ficha de caso y el código del runner contienen peticiones, datos sintéticos y comprobación de base. **Esperado:** La fila permanece con marca lógica. **Obtenido:** DELETE responde 200 y la consulta posterior retorna cero filas.

Impacto: Pérdida de información clínica y posible cascada de adjuntos. **Recomendación:** Soft delete transaccional y políticas coherentes de consulta y conservación. **Evidencia:** resultados_api.json, fila CP-API-007, y capturas del resumen de ejecución. **Responsable propuesto:** desarrollo backend; revisión QA. **Retest:** repetir positivo y negativo, comprobar persistencia y ejecutar regresión de roles y sesiones.

DEF-004 — Latencia fuera de criterio

Caso y severidad: CP-API-011; GRAVE / Alta. **Entorno:** API 4445, base cuidarte_qa sintética. **Estado:** abierto.

Pasos reproducibles: ejecutar el script y localizar CP-API-011; la ficha de caso y el código del runner contienen peticiones, datos sintéticos y comprobación de base. **Esperado:** 200 y menos de 300 ms. **Obtenido:** GET /examenes supera 300 ms; hay delayMiddleware(5000).

Impacto: Demora operativa para personal clínico y pacientes. **Recomendación:** Retirar simulación del entorno objetivo y repetir carga representativa. **Evidencia:** resultados_api.json, fila CP-API-011, y capturas del resumen de ejecución. **Responsable propuesto:** desarrollo backend; revisión QA. **Retest:** repetir positivo y negativo, comprobar persistencia y ejecutar regresión de roles y sesiones.

DEF-005 — Escalamiento de médico a administrador

Caso y severidad: CP-API-010; CRÍTICO. **Entorno:** API 4445, base cuidarte_qa sintética. **Estado:** abierto.

Pasos reproducibles: ejecutar el script y localizar CP-API-010; la ficha de caso y el código del runner contienen peticiones, datos sintéticos y comprobación de base. **Esperado:** 403 y rol médico conservado. **Obtenido:** Médico modifica su propio rol con HTTP 200 y queda como admin en usuario_roles.

Impacto: Pérdida de separación de privilegios y posible exposición masiva de datos. **Recomendación:** Exigir administrador para cualquier cambio de rol; probar todos los roles y revocación. **Evidencia:** resultados_api.json, fila CP-API-010, y capturas del resumen de ejecución. **Responsable propuesto:** desarrollo backend; revisión QA. **Retest:** repetir positivo y negativo, comprobar persistencia y ejecutar regresión de roles y sesiones.

DEF-006 — Eliminación de usuario sin autenticar

Caso y severidad: CP-API-012; CRÍTICO. **Entorno:** API 4445, base cuidarte_qa sintética. **Estado:** abierto.

Pasos reproducibles: ejecutar el script y localizar CP-API-012; la ficha de caso y el código del runner contienen peticiones, datos sintéticos y comprobación de base. **Esperado:** 401 y cuenta intacta. **Obtenido:** DELETE /usuarios/:id sin token devuelve 200 y elimina la cuenta sintética.

Impacto: Acción destructiva anónima sobre gestión de usuarios. **Recomendación:** Autenticar y autorizar antes de mutar; control por recurso, transacción y regresión negativa. **Evidencia:** resultados_api.json, fila CP-API-012, y capturas del resumen de ejecución. **Responsable propuesto:** desarrollo backend; revisión QA. **Retest:** repetir positivo y negativo, comprobar persistencia y ejecutar regresión de roles y sesiones.

DEF-001 se refiere a la tabla real auditoria y a RF-5.1. La dirección de origen debe obtenerse de la conexión o de un proxy confiable, sin aceptar cabeceras arbitrarias. La omisión de IP es un incumplimiento del criterio técnico adoptado, no prueba automática de infracción a la Ley 21.663. La protección de auditoría debe incluir atomicidad, mínimos privilegios y resistencia a alteración; añadir una columna no basta.

Anexo A. Análisis ético, normativo y responsabilidades

Una publicación con contraseñas inseguras o adjuntos accesibles puede exponer diagnósticos y facilitar suplantación. El borrado físico amenaza continuidad y evidencia clínica; la demora artificial perjudica la atención. La falta de trazabilidad dificulta investigar incidentes. Éticamente corresponde limitar el uso a datos sintéticos, restringir el entorno y comunicar con precisión qué se comprobó, evitando presentar herramientas planificadas como certificaciones obtenidas.

6.1 Responsabilidades y consecuencias

Actor	Responsabilidad operativa propuesta	Exposición normativa que debe analizarse
Institución de salud responsable del tratamiento	Definir finalidad, base habilitante, accesos, conservación y respuesta a titulares	Obligaciones de protección y eventual responsabilidad por tratamiento indebido
CreaLab como proveedor, según contrato y rol efectivo	Implementar controles, subsanar defectos y proteger los datos tratados por encargo	Obligaciones contractuales y legales según funciones y aplicabilidad
Administración y operación	Mínimos privilegios, respaldos, monitoreo y gestión de incidentes	Deberes de ciberseguridad que correspondan a la entidad
Desarrollo y QA	Corrección, pruebas, trazabilidad y comunicación de limitaciones	Responsabilidad técnica y profesional; no se presume multa personal automática
Médico, administrador y paciente	Uso autorizado de cuentas y recursos	Consecuencias dependen de conducta, daño y régimen aplicable

La Ley 19.628 contempla indemnización por daños patrimoniales y morales derivados del tratamiento indebido, bajo sus presupuestos [L3]. La Ley 21.663 prevé multas graduadas: el máximo de 40.000 UTM corresponde al supuesto de infracción gravísima de un operador de importancia vital; no es una multa automática por omitir una IP ni aplicable sin determinar sujeto y conducta [L2]. Se debe verificar clasificación, procedimiento y circunstancias concretas.

La Ley 21.719 se incorpora como preparación para su próxima vigencia [L1]. Este dictamen técnico no determina sanciones, causalidad de daños ni certifica cumplimiento jurídico integral. Antes del despliegue debe completarse la matriz de obligaciones aplicables, incluyendo las reglas sectoriales de información clínica que correspondan, sin asumir que las tres leyes citadas agotan el marco normativo.

Anexo B. Certificación y recomendaciones

Dictamen: NO CERTIFICADO para producción. Dos defectos críticos permiten escalar privilegios y eliminar una cuenta sin sesión. Cuatro defectos graves afectan contraseñas, conservación, trazabilidad y desempeño. No se cumplen los criterios de salida y faltan DAST, cobertura de código, carga sostenida y accesibilidad completa. Ningún riesgo crítico se considera aceptado por defecto.

Prioridad inmediata: autenticar y autorizar antes de cualquier mutación y restringir cambios de rol a administración. Después proteger contraseñas, implementar borrado lógico y auditoría transaccional, y retirar demoras de simulación del entorno objetivo. Repetir los doce checkpoints y ampliar a ERS, unitarias, E2E, DAST, WCAG y carga sostenida. Se requiere evidencia de cierre, no solo modificación del código.

El equipo podrá reevaluar la certificación cuando no existan críticos o graves abiertos y se acrediten los criterios de aceptación. No se ofrece una certificación jurídica ni ISO por emitir este informe académico.

Anexo C. Fuentes y limitaciones

Consulta realizada el 20 de octubre de 2026. Los enlaces externos respaldan el marco técnico y normativo; los resultados del proyecto se sustentan en los documentos y archivos locales descritos.

- [L1] Biblioteca del Congreso Nacional. Ley 21.719 y disposiciones transitorias: https://www.bcn.cl/leychile/navegar?i=1209272

- [L2] Biblioteca del Congreso Nacional. Ley 21.663, ámbito de aplicación y escala de multas: https://www.bcn.cl/leychile/navegar?idNorma=1202434&idVersion=2025-01-01

- [L3] Biblioteca del Congreso Nacional. Ley 19.628, versión anterior a la entrada en vigor de la reforma; artículos 10 y 23: https://www.bcn.cl/leychile/Navegar?idNorma=141599&idVersion=2023-05-09

- [T1] ISO. ISO/IEC 25010:2023, Product quality model: https://www.iso.org/standard/78176.html

- [T2] W3C. Web Content Accessibility Guidelines 2.1: https://www.w3.org/TR/WCAG21/

- [T3] SonarSource. Understanding measures and metrics: https://docs.sonarsource.com/sonarqube-server/user-guide/code-metrics/metrics-definition

La pauta EP4 proporcionada está rotulada 2025 y en un párrafo menciona Evaluación Parcial 2; se conserva el original y se sigue su encabezado EP4, ponderación 28%, defensa individual de 10 minutos más 5 de preguntas. No se alteró la pauta para resolver esas inconsistencias editoriales. Las guías de aula contienen ejemplos (50 casos, 48 ejecutados, etc.) que no se usaron como resultados de Cuidarte+.

Pendientes reales: ERS íntegra y feedback docente; grabación nativa de Chrome Recorder/TestCase Studio/Selenium IDE si la docente la exige específicamente; DAST y cobertura; evaluación AA y usuarios; carga sostenida. El paquete contiene toda la documentación posible y registra estas limitaciones expresamente.